Threat Intelligence Capstone Project

Harmony Health Threat Investigation

SOC Investigation Report: Executive Summary (5 pages) | Part A and Part B

Prepared by Faith Ejele, SOC Analyst | 10alytics, 2026 | 27 October 2026 | Internal – Confidential

Condensed from the full 100-page report. Figure references (E1-nn to E5-nn, PB-nn) point to its appendices. Indicators are defanged.

1. Executive summary

Verdict: all four emails are very likely phishing or fraud attempts. In Part B, Wazuh detected two of three simulated threats end to end; the YARA scan result is not shown. No compromise, payment loss or malware execution is confirmed.

Case ID	Subject	Priority	Verdict
TIC-PH-E2	Supplier invoice fraud (BEC), USD $47,250	CRITICAL	Fraud attempt; confirm no payment was made
TIC-PH-E5	Bank of America credential phishing	HIGH	Phishing attempt; recipient interaction unknown
TIC-PH-E1	Microsoft account-suspension phishing	HIGH	Phishing attempt; check sign-in logs
TIC-PH-E4	DHL redelivery fee phishing with ZIP	MEDIUM-HIGH	Phishing attempt; ZIP looks like a stub
TIC-WZ-01	Malware samples and YARA integration	MEDIUM (lab)	FIM detection verified; YARA match not shown
TIC-WZ-02	Trojaned /usr/bin/w	MEDIUM (lab)	Detected by rootcheck rule 510; heuristic signature
TIC-WZ-03	Shellshock attack pattern	HIGH alert (lab)	Pattern detected (rule 31168, level 15); exploitation not indicated

- **Common pattern.** Every email shows a brand/domain mismatch, reported SPF, DKIM and DMARC failures and a placeholder DKIM signature.
- **Linked cases.** Emails 1 and 5 use 185.220.101.47 and 91.108.56.122 in swapped roles. All four were delivered through relays in 10.114.72.0/24 and share a one-year timestamp shift: one actor, one template or a constructed data set.
- **Check payment first.** Email 2 carries the largest exposure; its 22 April 2026 deadline has passed, so the first question is whether a payment was made.
- **Part B.** Real-time FIM raised rules 100300/100301 with a consistent hash chain; rootcheck rule 510 flagged the replaced binary from 03:20:34 WAT; rule 31168 flagged the Shellshock User-Agent at 04:03:38 WAT but the server returned the stock Apache page.
- **Confidence.** Phishing conclusion: high. Routing and authentication detail: low to medium (screenshots of .eml files, no gateway logs). Part B alerts: high (alert documents on screen). The email set looks like training data (placeholder DKIM, patterned strings, 2025 timestamps) and is analysed as live.

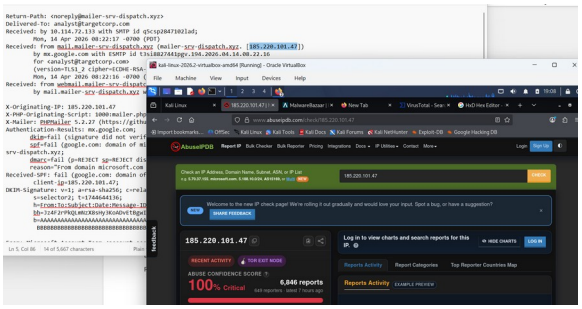


Figure E1-01. AbuseIPDB lookup for 185.220.101.47 (Tor exit, 100%)

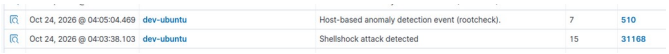


Figure PB-76. Wazuh events: Shellshock (level 15, rule 31168) and rootcheck (rule 510)

2. Lab preparation and restoration

Part A used a Kali VM browser (AbuseIPDB, VirusTotal, MalwareBazaar), a web base64 decoder, HxD and online header analysers on screenshots of original .eml files; nothing was executed. Part B ran on a Wazuh server (192.168.1.100), agent 001 dev-ubuntu (192.168.1.105, Ubuntu 24.04.3) and a Kali attacker (192.168.1.103). Times are WAT (UTC+1), 24 October 2026.

2.1 Preparation (Part B, as shown in the screenshots)

Step	Evidence	Figures
YARA 4.5.5	Dependencies installed, built from source, make check 16/16 passed; Valhalla demo rules requested.	PB-01 to PB-04
Active response script	yara.sh takes the YARA path, rules and scanned file from the alert JSON.	PB-05
Real-time FIM	syscheck frequency 60, scan_on_start, /tmp/yara/malware realtime; agent restarted.	PB-07, PB-08
Manager rules and decoders	Rules 100300, 100301, 108000; yara_decoder pair; command yara_Linux on rules 100300,100301; manager restarted.	PB-10 to PB-13
Samples	Downloader run: Mirai errored; Xbash, VPNFilter, WebShell done.	PB-19 to PB-22
Rootcheck and Apache	check_trojans on, frequency 60; Apache2 installed and default page loaded.	PB-57, PB-67 to PB-70
Dashboard readiness	1 active agent; Threat Hunting and Events views used.	PB-23 to PB-29

2.2 Safety controls and concerns

- Indicators defanged; no live link or attachment opened from a production machine; lab samples stay in the isolated VM.
- A decoded PNG was saved as BecFake.pdf in a Windows profile and opened in a browser (E2-12), and a web decoder corrupted the Email 1 PDF (E1-11). Use an isolated machine and base64 -d.

2.3 Restoration

No restoration step appears in the screenshots; the trojaned file was still alerting at 04:05:04 WAT. The procedure below is recommended, not evidenced.

Item	State after the lab	Restoration action	Verification
/usr/bin/w	Overwritten by a script; original at /usr/bin/w.copy	sudo mv -f /usr/bin/w.copy /usr/bin/w (or reinstall procps)	dpkg --verify procps; rule 510 stops
/tmp/trojan_created_file	Created by the script	Delete	File absent
/tmp/yara/malware	Xbash, webshell, other samples, downloader	Record hashes, then delete	Folder empty
Wazuh config	Realtime syscheck, rules, yara_Linux	Back up ossec.conf; keep or remove blocks; restart	Services active
Apache2, ufw, sshd	Apache running; ufw inactive; sshd started by hand	systemctl disable --now apache2 and sshd; review ufw	Ports 80 and 22 closed
VMs and workstation	Test commands; decoded attachments, e.g. BecFake.pdf	Revert snapshots; delete decoded files; store originals read-only with SHA-256	No artefacts remain
Alert evidence	Index wazuh-alerts-4.x-2026.10.24	Export alerts and screenshots first; keep the index	Export saved with hash

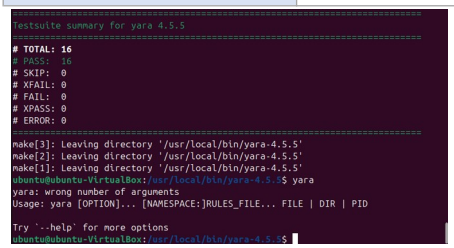


Figure PB-03. YARA 4.5.5 test suite: 16 of 16 passed



Figure PB-10. Custom rules 100300, 100301 and group 108000

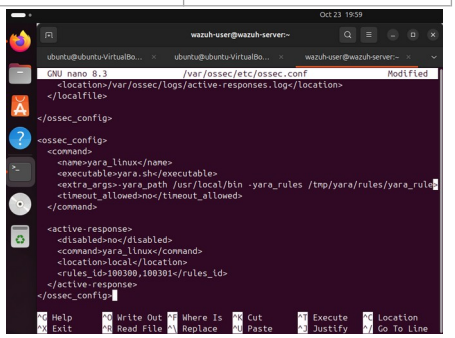


Figure PB-12. yara_linux command and active response on rules 100300,100301

3. Phishing investigations (Part A): investigation summary template

Field	TIC-PH-E1 Microsoft credential phishing	TIC-PH-E2 Invoice fraud (BEC)	TIC-PH-E4 DHL fee phishing + ZIP	TIC-PH-E5 Bank of America phishing
What happened	14 Apr 2026 15:22 UTC: "Microsoft Account Team" says the account is suspended; 24 h to verify via lookalike link; PDF repeats it.	15 Apr 17:47 UTC: "Delta Supplies Corp" asks the CFO for USD $47,250 by 22 Apr to a new Riga account; replies to an off-domain mailbox.	17 Apr 20:05 UTC: "DHL" says a parcel failed; $2.99 fee and address on a lookalike site; ZIP of "customs forms".	18 Apr 14:31 UTC: "Bank of America" claims Tor-exit access; account restricted; reset within 12 h on a lookalike domain.
Evidence references	E1-17 to E1-23 (.eml); E1-01 to E1-06 (AbuseIPDB, hops); E1-10 to E1-14 (PDF)	E2-13 to E2-19 (.eml); E2-01 to E2-09 (VirusTotal, AbuseIPDB); E2-12	E4-13 to E4-19 (.eml); E4-01 to E4-03, E4-09 (AbuseIPDB); E4-11, E4-12 (ZIP)	E5-04, E5-05, E5-07, E5-09, E5-10 (.eml); E5-01 to E5-03, E5-06 (AbuseIPDB)
Relevant indicators	185.220.101.47; mailer-srv-dispatch[.]xyz; account-ms365-verify[.]top; login-microsoft365-verify[.]top; account_verification.pdf	194.165.16.101/.88; fast-invoice-send[.]ru; biz-invoice[.]ru; IBAN LV82HABAL0000034567891; invoice DS-2026-04418	176.111.174.55/.33; dhl-delivery-info[.]xyz; tracking 1928374650; ShippingDocs_1928374650.zip	91.108.56.122/.99; secure-boa-alerts[.]cc; case ID BOA-SEC-2026-119847; Security_Notice PNG
Confirmed findings	Four-domain identity mismatch; SPF/DKIM/DMARC reported failed, DKIM placeholder; link text shows microsoft.com but targets the lookalike; AbuseIPDB: 185.220.101.47 is a Tor exit, 100%, 6,846 reports (about 16 Oct 2026).	Domain mismatch; permanent bank change; IBAN (22 chars), BIC (12) and phone fail format checks; DKIM placeholder; PNG is a mostly-zero stub; AbuseIPDB 0% (old scans).	Domain mismatch; fee lure off-brand; DKIM placeholder; ZIP is about 160 bytes with one .txt member and inconsistent size fields; no executable visible.	Domain mismatch; off-brand reset link; DKIM placeholder; IP role swap with Email 1; Tor "Bucharest" claim contradicts AbuseIPDB (Berlin).
Unconfirmed points	Click or credential entry; true SMTP peer; gateway disposition; PDF hash; domain reputation.	Whether any payment was made; whether the supplier domain is genuine; attachment hash; domain reputation.	Click, payment or ZIP opened; ZIP integrity and hash; domain reputation.	Click or credentials; whether the recipient banks there; attachment hash; domain reputation.
Verdict and confidence	Phishing: HIGH. Routing/auth: LOW-MEDIUM. Priority HIGH.	Fraud: HIGH. Routing/auth: LOW-MEDIUM. Priority CRITICAL.	Phishing: HIGH. Routing/auth: LOW-MEDIUM. Priority MEDIUM-HIGH.	Phishing: HIGH. Routing/auth: LOW-MEDIUM. Priority HIGH.
Response and escalation rationale	Check exposure and Microsoft sign-ins from 14 Apr; reset and revoke if odd; block 3 domains. Escalate to identity admin: credentials unlock mail, files and SSO.	Ask finance and bank if paid; recall if so; verify out of band; block domains and IPs. Escalate to finance director and bank fraud desk: loss risk, recovery falls with time.	Ask whether clicked, paid or opened; tell card issuer if card entered; isolate endpoint if ZIP opened; block domain (not dhl[.]com).	Establish interaction; advise bank contact via app; block domain (not bankofamerica[.]com); find other recipients. Escalate to bank fraud channel if credentials entered.

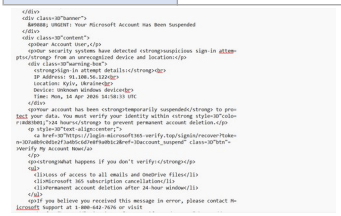


Figure E1-21. Email 1 HTML body: suspension lure

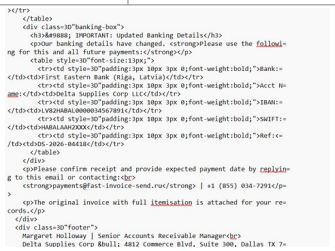


Figure E2-18. Email 2 banking box

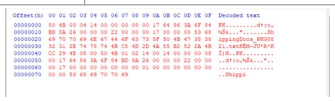


Figure E4-12. Email 4 ZIP bytes in HxD

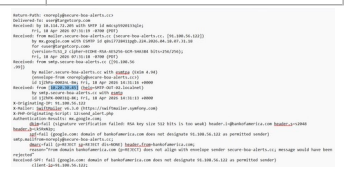


Figure E5-04. Email 5 top headers (SPF/DKIM/DMARC fail)

4. Wazuh detection (Part B): investigation summary template

Field	TIC-WZ-01 Malware samples and YARA	TIC-WZ-02 Trojaned binary /usr/bin/w	TIC-WZ-03 Shellshock pattern
What happened	Wazuh prepared with YARA 4.5.5, realtime FIM on /tmp/yara/malware and an active response on rules 100300/100301. A downloader dropped Xbash, VPNFilter and WebShell samples; FIM alerted as files were added and grew.	At 03:19:06 WAT /usr/bin/w was copied then overwritten with a bash script that writes a marker file and runs the original. Rootcheck alerted about 90 seconds later.	Kali (192.168.1.103) sent User-Agent "() { :; }; /bin/cat /etc/passwd" to Apache on the agent. Wazuh decoded the access log and alerted at 04:03:38 WAT.
Evidence references	PB-01 to PB-03; PB-05, PB-07, PB-10 to PB-13; PB-19 to PB-22; PB-31 to PB-40; PB-51 to PB-56	PB-57; PB-58, PB-59; PB-62 to PB-64; PB-66; PB-82	PB-67 to PB-70; PB-73; PB-76; PB-78 to PB-80; PB-84 to PB-86
Alert details	Rule 100301 (file added: webshell); rule 100300 fired 63 to 67 times. xbash 7,737,344 → 7,868,416 → 7,983,104 → 9,568,976 bytes; MD5 d2e16464...→5bb6e4ae...; first alert 02:04:49 WAT.	Rule 510, level 7: "Trojaned version of file '/bin/w' detected. Signature used: 'uname -a|proc\.h|bash' (Generic)". Alerts 03:20:34 to 03:31:38, again 04:05:04.	Rule 31168 "Shellshock attack detected", level 15, CVE-2014-6271, MITRE T1068/T1190. Log: GET / HTTP/1.1 200 10926 from 192.168.1.103.
Confirmed findings	Realtime FIM detected added and modified samples; each "before" hash equals the previous "after" hash; YARA installed (16/16) and AR/decoder/rules configured.	Rootcheck flagged the replaced binary and kept alerting while it stayed in place; the generic signature matched "bash" in the script.	Pattern detected at the lab's highest level; the server returned the stock Apache page (HTTP 200, 10,926 bytes); target was "/", not a CGI script.
Unconfirmed points	That yara.sh ran or matched anything (no "wazuh-yara" event); rules path /tmp/yara/rule vs rules; coverage of the demo rules.	That /bin/w is the same file as /usr/bin/w (normal link, not shown); any syscheck alert for it; that the file was restored.	Any command execution; alert ID epoch (≈03:16:58 UTC) does not match the 04:03:38 +0100 log (likely OCR error); any block of the source.
Verdict and confidence	FIM detection HIGH; YARA NOT demonstrated; overall partly verified.	Detection verified HIGH; strength MEDIUM-LOW (generic signature).	Pattern detected HIGH; exploitation NOT indicated.
Response and escalation rationale	Run yara on xbash, screenshot the "wazuh-yara:" event, confirm the rules path, add a rule under 108000. Lab only; in production a real match goes to incident response.	Restore from w.copy, remove marker, add syscheck hash alerts on /usr/bin. A replaced system binary signals persistence; isolate the host if real.	Test with a real CGI script; add firewall-drop on rule 31168; patch Apache/bash. Escalate if a CGI path returns 200 or outbound connections follow.

4.1 Monitoring verification matrix

Control	Result	Evidence
Agent connected; real-time FIM; rootcheck; Apache log; rule 31168	Verified	PB-23, PB-24; PB-31 to PB-40, PB-51 to PB-56; PB-62, PB-82; PB-78; PB-76 to PB-80
YARA installed; rules downloaded; AR, decoder and rule 108000	Configured	PB-03; PB-04, PB-09; PB-10 to PB-12 (execution and rule file not shown)
YARA scan result in Wazuh	Not shown	No "wazuh-yara: ... Scan result" event in any screenshot



Figure PB-51. FIM alert: xbash modified (realtime)



Figure PB-62. Rootcheck alert: trojaned /bin/w



Figure PB-80. Shellshock alert fields (rule 31168)

5. IOC extraction and enrichment

Type	Indicators (defanged)	Cases	Enrichment shown (about 16–17 Oct 2026)
Domains	mailer-srv-dispatch[.]xyz; account-ms365-verify[.]top; login-microsoft365-verify[.]top; fast-invoice-send[.]ru; biz-invoice[.]ru; dhl-delivery-info[.]xyz; secure-boa-alerts[.]cc	E1, E2, E4, E5	None for any domain (VirusTotal 0/93 on one sub-domain URL). Verify deltasupplies-corp[.]com before blocking.
IPs	185.220.101.47; 91.108.56.122/.99; 194.165.16.101/.88; 176.111.174.55/.33	E1 to E5	Tor exit 100%, 6,846 reports; 9% Telegram range; 0% Flyservers and NUBES (old reports)
URLs	hxxps://login-microsoft365-verify[.]top/signin/recover?token=...; hxxps://dhl-delivery-info[.]xyz/reschedule?...fee=2.99; hxxps://secure-boa-alerts[.]cc/online-banking/verify?cid=...	E1, E4, E5	Not enriched
Files, finance, IDs	account_verification.pdf; Invoice PNG; Security_Notice PNG; ShippingDocs ZIP; IBAN LV82HABAL0000034567891; DS-2026-04418; 1928374650; BOA-SEC-2026-119847	E1, E2, E4, E5	No SHA-256 (originals not supplied); payment details fail format checks
Wazuh / host	192.168.1.103; /tmp/yara/malware/xbash; /usr/bin/w; rules 100300, 100301, 510, 31168	WZ-01 to 03	Detections in section 4

Lookups were made about six months after the emails. A 0% AbuseIPDB score on old scan reports does not clear an IP, and a high score on a shared Tor exit identifies the relay, not an attacker. No attachment hashes exist because the original bytes were not supplied.

6. Cross-case analysis and MITRE ATT&CK

- Emails 1 and 5 swap two IPs; all four emails reached 10.114.72.0/24 relays inside a five-day window (14–18 April 2026) with placeholder DKIM values and the same one-year timestamp shift.
- Phishing (E1, E4, E5): T1566.002, T1598, T1656, T1583.001; attachments T1566.001 (unconfirmed); T1204 only if clicked or opened. BEC (E2): T1656 plus fraud handling. Part B: T1105 (inferred), T1554 (closest mapping), T1068 and T1190 (tagged on rule 31168).

7. Response recommendations and escalation

Action / trigger	Escalate to	When	Rationale
Confirm whether the Email 2 invoice was paid; recall if so	Finance director, bank fraud desk	Immediately	Recovery odds fall with time
Establish click/credential exposure; review sign-ins; block six domains and IPs	Identity admin, incident response	Same day	Credentials unlock mail, files, SSO
ZIP or PDF opened or card entered	Endpoint response, card issuer	Same day	Possible malware or card theft
Retrieve originals; redo SPF/DKIM/DMARC; hash attachments; dated domain and IP lookups	Mail admin, threat intel lead	This week	Closes the main evidence gaps
Restore /usr/bin/w; show the wazuh-yara event; add syscheck hashes; test Shellshock with a CGI	Detection engineering	This week	Closes the Part B gaps
Enforce DMARC; callback and second approver for bank changes; phishing-resistant MFA; lookalike alerts; awareness training	Security and finance leads	Longer term	Prevents recurrence

8. Gaps and conclusion

Gaps: original .eml files and attachments; SPF/DKIM/DMARC reproduction; gateway disposition; domain reputation; user interaction records; YARA scan result; restoration; some Part B times and hash digits read from small text.

Conclusion: Part A shows four deliberate social-engineering attempts from unrelated infrastructure with failed authentication; none is shown to have succeeded. Part B shows Wazuh detecting file changes, a trojaned binary and a Shellshock string; the YARA result and restoration are still to be evidenced. Confirm the Email 2 payment position first, then recipient exposure for Emails 5, 1 and 4.

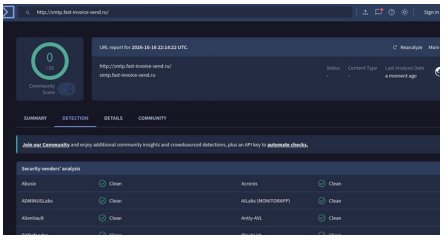


Figure E2-01. VirusTotal URL report: 0 of 93 (sub-domain only)

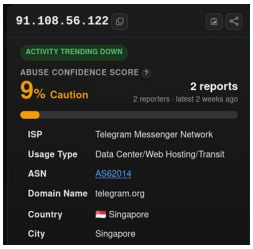


Figure E5-02. AbuseIPDB: 91.108.56.122, 9%, Telegram range

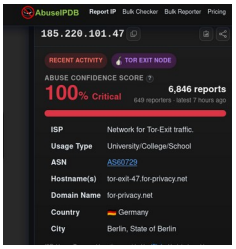


Figure E1-02. AbuseIPDB: Tor exit network details